Université Loyola du Congo

Faculté des Sciences et Technologies – Génie Informatique

PROJET MON MIAM MIAM

Sécurité, Gouvernance des Données & Plan de Continuité

Document 5 : Analyse des Risques, Politiques RLS & Minimisation des Données

Auteurs : Équipe Projet Génie Informatique (Groupe API)
Cible Opérationnelle : Restaurant Pilote ZeDuc@Space (Campus Yansoki, Kinshasa)
Environnement de Données : Supabase / PostgreSQL (21 Tables avec RLS)
Date : 27 Octobre 2026 — Version V2.0 Définitive

Table des matières

1 Introduction et Objectifs de Sécurité **2**

2 Matrice d'Analyse et de Mitigation des Risques **2**

3 Politique de Sécurité et Politiques RLS (PostgreSQL) **2**
3.1 Principes de Cloisonnement Multi-Restaurants 2

4 Confidentialité et Minimisation des Données **3**

5 Conclusion et Validation Finale **3**

1 Introduction et Objectifs de Sécurité

Le présent document constitue le volet final des spécifications de conception du projet **Mon Miam Miam**. Il formalise la stratégie de gestion des risques technologiques, l'architecture de sécurité des données au niveau des lignes (Row-Level Security — RLS) sur les 21 tables PostgreSQL, ainsi que les règles de minimisation et de confidentialité applicables au restaurant **ZeDuc@Space**.

2 Matrice d'Analyse et de Mitigation des Risques

Risque Identifié	**Criticité**	**Impact Potentiel**	**Mesure de Mitigation**
Divulgation de réponses de réclamations non approuvées	Élevée	Un client consulte une réponse en statut `proposed` ou `rejected`	Correction stricte des politiques RLS et filtrage côté API pour masquer toute réponse non validée par le gérant.
Manipulation des soldes de points de fidélité	Élevée	Crédits frauduleux ou double dépense de points	Utilisation exclusive de transactions atomiques (RPC), clés d'idempotence et interdiction de modifier le solde sans écriture dans le journal.
Fuite de données personnelles (PII)	Moyenne	Exposition des numéros de téléphone et adresses de livraison	Cloisonnement strict, masquage des adresses après clôture de la livraison et minimisation des champs exposés au personnel.
Conflits monétaires ou d'arrondi	Moyenne	Erreurs de facturation ou de calcul de points	Standardisation de la devise en Francs Congolais (CDF) et application stricte du calcul par tranches entières.

TABLE 1 – Matrice des Risques Majeurs et Stratégies de Correction

3 Politique de Sécurité et Politiques RLS (PostgreSQL)

L'architecture de la base de données de Caleb repose sur l'activation de la sécurité au niveau des lignes (Row-Level Security) sur l'ensemble des 21 tables du schéma public.

3.1 Principes de Cloisonnement Multi-Restaurants

- **Isolation par Établissement :** Chaque ressource opérationnelle (produits, commandes, paramètres, comptes de fidélité) est liée à un `restaurant_id`. Les clés étrangères composites garantissent qu'aucun utilisateur ne peut croiser des données entre deux restaurants distincts.
- **Rôles Locaux du Personnel :** Les attributions de personnel (`staff_assignments`) définissent les rôles locaux (`employee`, `manager`, `admin`) pour un restaurant précis. Un employé révoqué perd immédiatement ses droits d'accès.
- **Protection des Secrets :** Les clés sensibles (`service_role` Supabase, secrets de paiement) sont stockées exclusivement côté serveur et ne sont jamais exposées dans le code client ou les bundles frontend.

4 Confidentialité et Minimisation des Données

Conformément aux exigences de minimisation :

- **Authentification :** Les mots de passe et jetons de session sont gérés exclusivement par Supabase Auth ; aucune donnée d'authentification sensible n'est répliquée en clair dans la table `profiles`.
- **Données de Paiement :** Seuls les identifiants de transaction fournis par le prestataire et les statuts de paiement sont conservés. Aucune donnée sensible de carte bancaire (PAN / CVV) n'est stockée dans la base de données.
- **Conservation :** Les adresses de livraison et historiques de commandes sont conservés selon les finalités opérationnelles et comptables, avec des procédures d'anonymisation prévues en fin de cycle de vie.

5 Conclusion et Validation Finale

La mise en œuvre conjointe des règles de gestion validées, du dictionnaire de données, des API sécurisées et de ce plan de gestion des risques garantit à l'équipe du projet **Mon Miam Miam** un cadre technique robuste, auditable et prêt pour le déploiement opérationnel au sein du restaurant **ZeDuc@Space**.